Høyskolen
Kristiania

Høyskolen Kristiania

Bokmål

Emnekode:	ETH2100
Emnenavn:	Etisk Hacking
Vurdering:	Mappevurdering, DEL 2
Innlevering:	21. november 2025
Filformat:	PDF (ingen vedlegg)

Eksamen er en mappevurdering og består av 3 deler. Delene skal leveres som 3 forskjellige innleveringer i Wiseflow. Karakter blir satt basert på ALLE delene som en helhet, alle 3 delene må være bestått. Se første forelesning for detaljer om karaktersetting.

Krav til DEL 2

- Filnavn skal være [kandidatnummer]_ETH2100_Eksamen_DEL2.pdf
- Skrevet som en profesjonell rapport
- Ved bruk av kilder skrives dette i «pentest-rapport» form; ikke litteraturliste eller referanser på slutten, men på form:
  - For mer detaljer se her: www.vg.no

Du får lov til å kopiere det du selv har skrevet i ditt eget arbeidskrav. Jeg har opplyst i forelesningen, og har skrevet inn i sensorveiledningen, at det IKKE er plagiat. Hensikten med arbeidskravet er å forberede dere til eksamen, jeg forventer derfor at dere vil bygge videre på rapporten dere skrev til arbeidskravet.

Boris' Lockpicks

Høyskolen Kristiania

www.h-ck.me/eth2100/exam25/ETH2100_H25_mappeeksamen_del2_vm.zip

www.h-ck.me/eth2100/exam25/ETH2100_H25_mappeeksamen_del2_source.zip

(Vær obs på at dette domenet brukes i undervisning av etisk hacking, ditt anti-virus program kan derfor rapportere domenet som «malicious», du må i så fall legge til et unntak for domenet…)

Boris Lockpicks

Kunden er Boris Lockpicks, og har fått utviklet en nettbutikk som nå er i beta versjon. Dere har tidligere jobbet på prosjektet og kjenner koden fra tidligere.

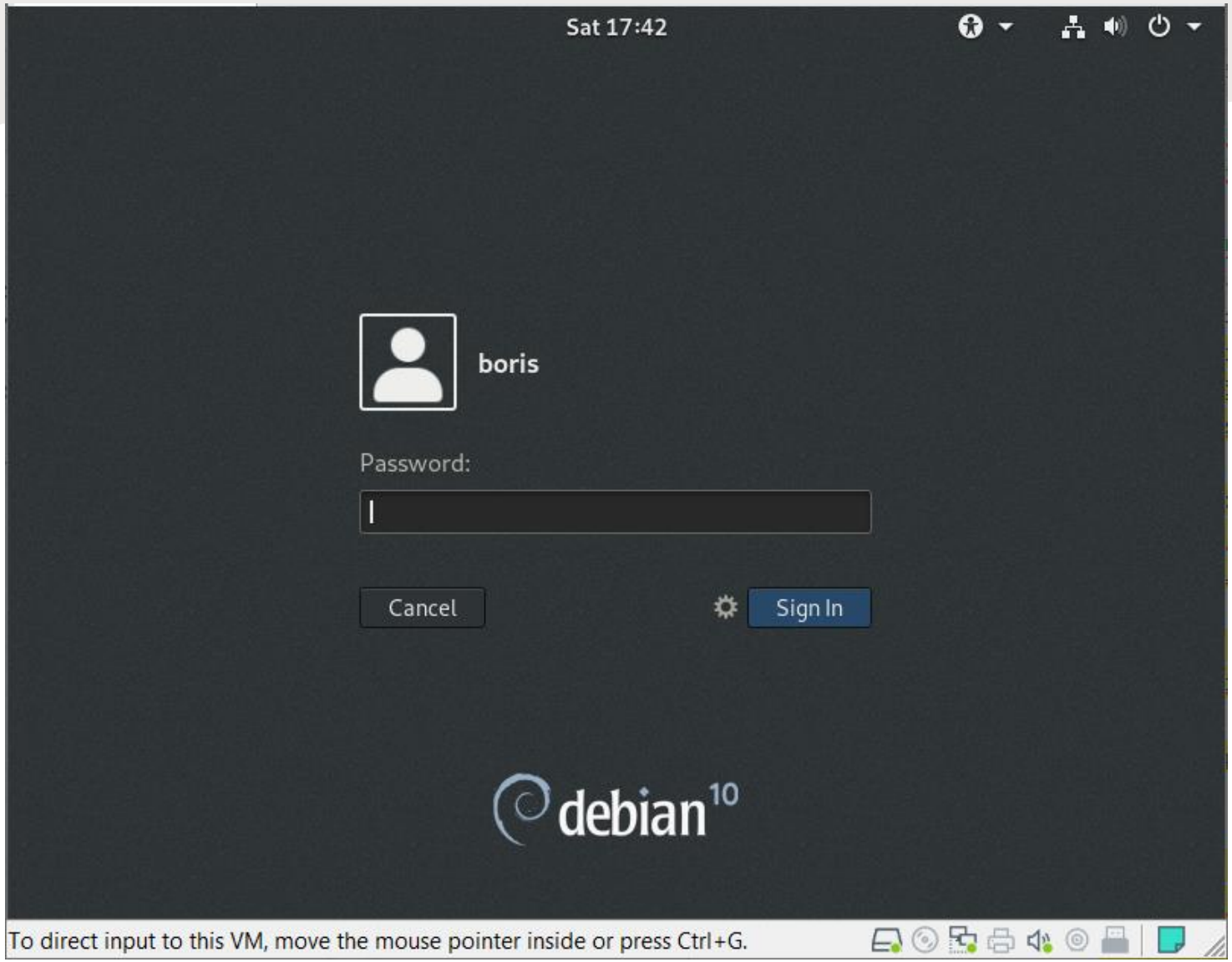
Kunden ønsker å gjennomføre en Web Application «pentest» av applikasjonen. Testen skal gjennomføres som en whitebox test, og dere bør gjennomføre statisk kodeanalyse.

Kildekode er lagt ved i filen `ETH2100_H25_mappeeksamen_del2_source.zip` som dere kan både finne under EKSAMEN på Canvas, eller på overnevnte URL.

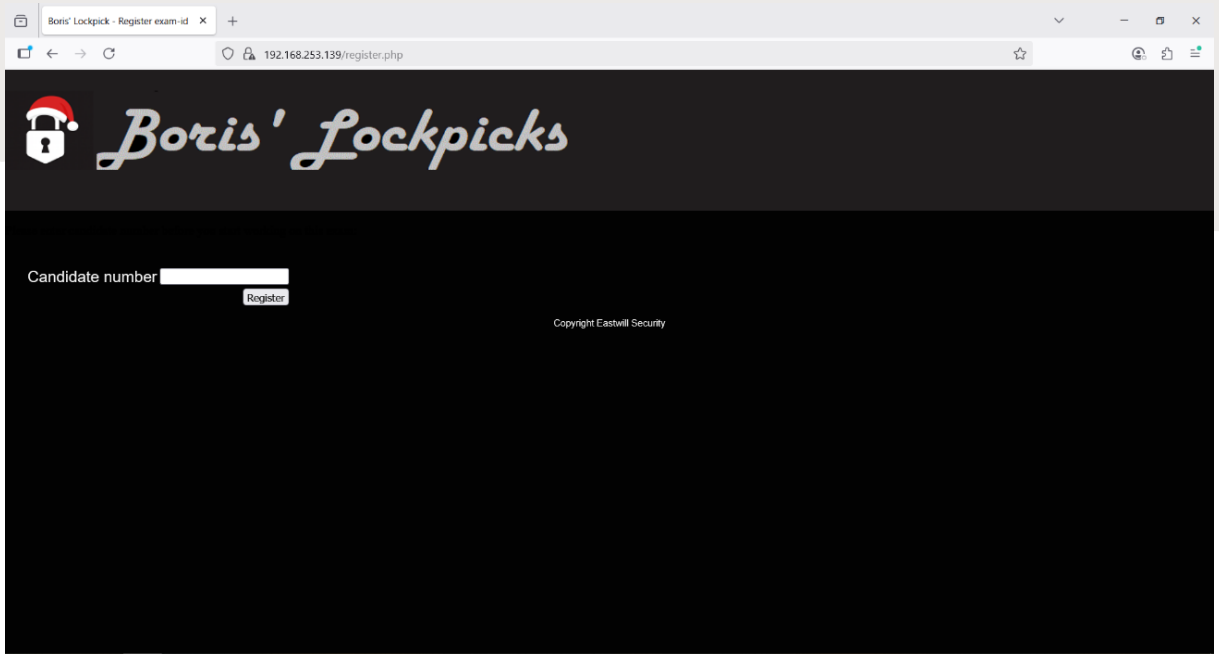
Boris Lockpicks

Kunden har ikke oppgitt noen brukere eller passord til systemet. (Det er innenfor scope å knekke passord for innlogging, og hvis det er mulig å finne passordet skal det i så fall rapporteres som en sårbarhet.)

Dere må først finne IP adressen til serveren. Serveren bruker dynamisk IP adresse gjennom DHCP som den vil motta fra deres VmWare, men da dere ikke får innloggingspassord til serveren må dere selv finne IP adressen som blir tildelt.


Sat 17:42
boris
Password:
Cancel
Sign In
debian 10
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

1.

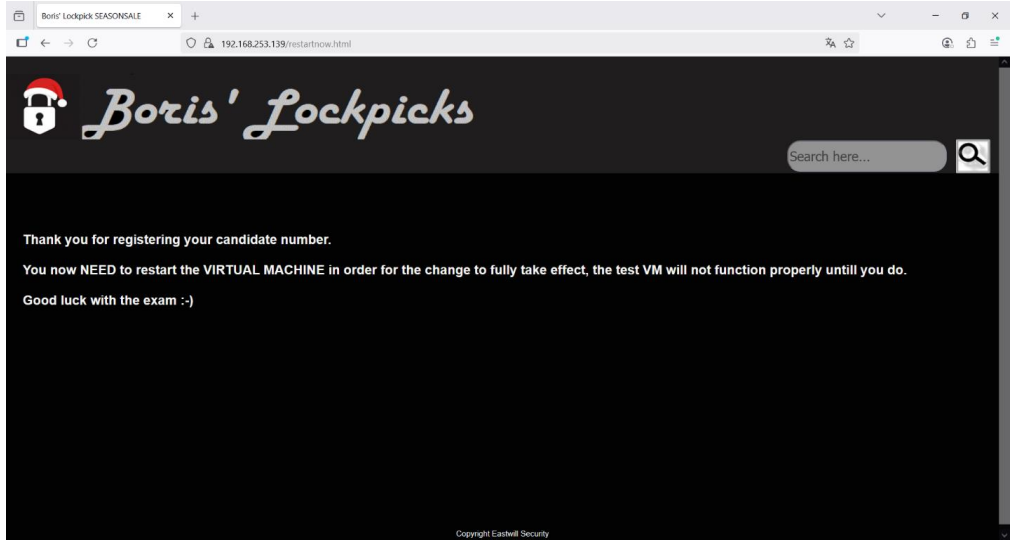


Før du kan starte testing av maskinen må du først registrere kandidatnummer, det gjøres ved å åpne opp IP adressen du fant at kjørte web applikasjonen og gå til websiden **register.php**.

192.168.253.139/register.php [erstatt IP adressen med din VM sin IP]

2.

Etter å ha registrert ditt kandidatnummer må maskinen restartes, når du trykket 'Register' skal du ha blitt vist følgende side:



3.

Etter en restart vil deler av serveren tilpasse sin oppførsel til kandidatnummeret du registrerte.

Boris Lockpicks

Det skal gjennomføres en «penetrasjonstest» (teknisk sårbarhetsrevisjon) av en web applikasjon.

Applikasjonen kan lastes ned fra H-CK.ME (link til filen fra emnesidene på Canvas), og ligger i filen `ETH2100_H25_mappeeksamen_del2_vm`. Filen inneholder et VmWare image dere skal starte, og som kjører en web applikasjon.

Imaget er konfigurert til å kun bruke adapteret Host-Only (VmNet1).

Oppstart av serveren

Webserveren Abyss WS starter automatisk i bakgrunnen når dere starter den virtuelle maskinen (dere trenger ikke starte noe manuelt, og trenger ikke logge inn). Installasjonen bruker HTTPS, og kan aksesseres i en nettleser (for eksempel) med https://192.168.253.140/ fra en annen maskin (Kali VM eller host maskinen). Merk at da IP er dynamisk tildelt vil IP adressen være forskjellig på deres systemer.

Dere skal ikke trenge å logge inn på serveren, Abyss starter i bakgrunnen uten innlogget bruker.

Da nettbutikken er i en beta fase kan det være noe funksjonalitet som ikke virker etter hensikten.

Out of scope

Viktig:

Dette er et fiktivt oppdrag til eksamen, derfor er «**Open Source Intelligence**» og «**Social Engineering**» out-of-scope og **skal ikke utføres.** (Dere har **ikke** tillatelse til å utføre noe testing eller simulere angrep mot selskapet Eastwill Security.)

Innlevert oppgave kan derfor hoppe over disse stegene i både metodikk og rapportering.

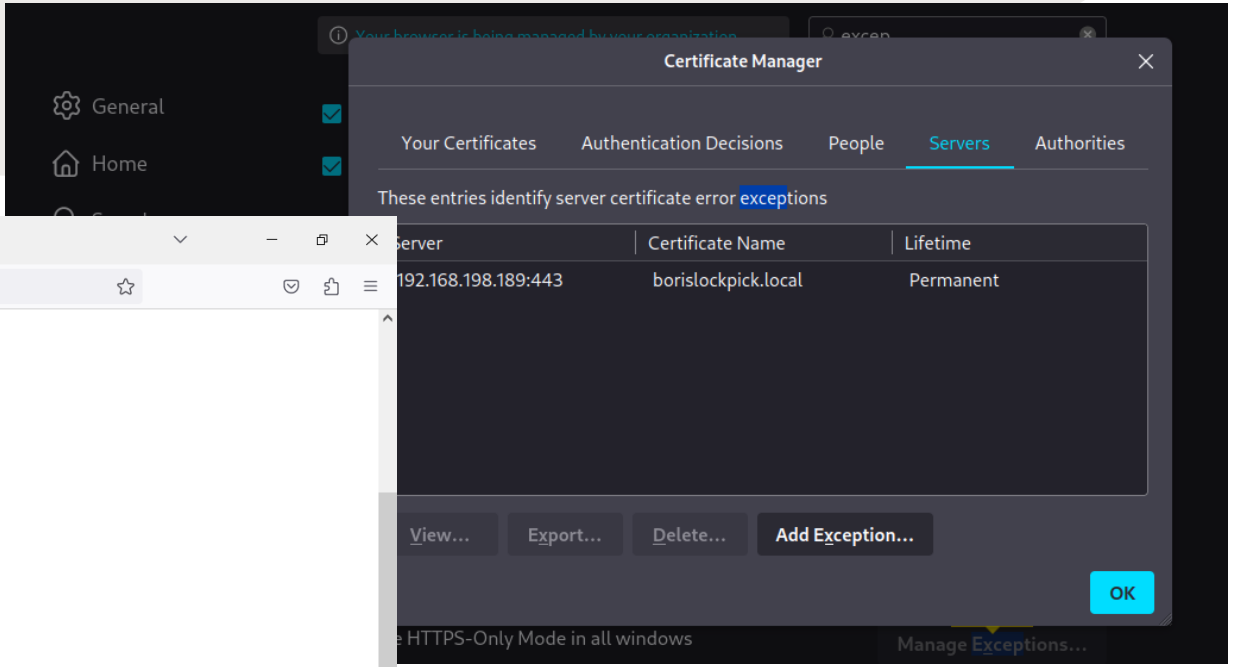
HTTPS sertifikater

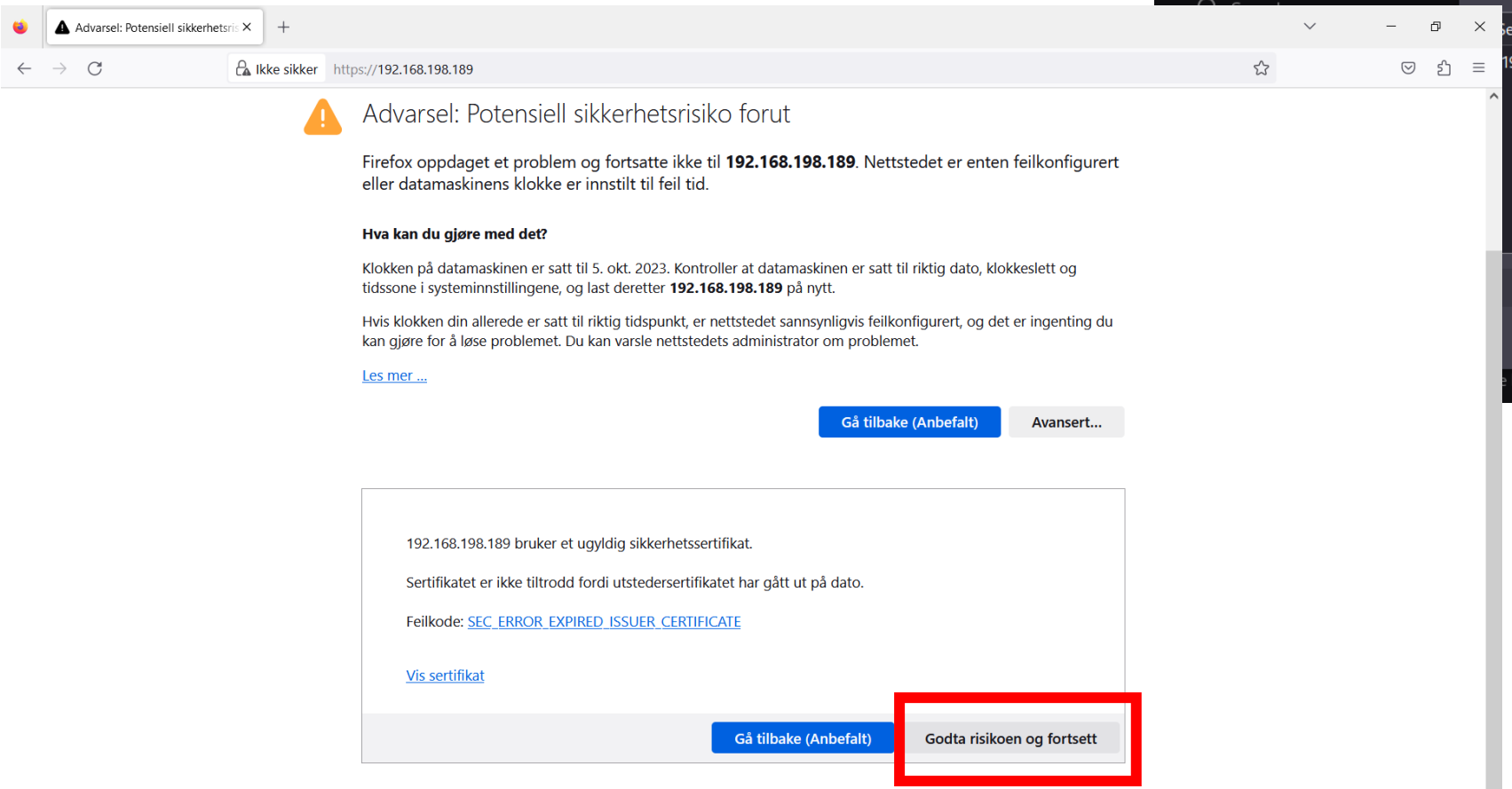
Viktig:

Da serveren ikke er i produksjon og ikke har et offentlig domenenavn er det brukt «Self Signed» TLS sertifikat.

1) At sertifikatet er «Self Signed» er ikke en sårbarhet og trenger ikke inkluderes i rapporten
2) Sertifikatet som vil bli brukt i produksjon er ellers likt det sertifikatet som her er satt opp
3) Nettlesere (som Firefox) vil anse serveren som utrygg da sertifikatet ikke kan valideres – dette må dere akseptere

HTTPS sertifikater





Innlevering av rapport

Kunden ønsker at dere tester alt på serveren, ikke bare webserveren på port 443.

Det presiseres at det skal leveres en skriftlig rapport fra denne delen av mappevurderingen, og denne rapporten skal leveres inn i Wiseflow, innen den endelige fristen for denne delen.

Høyskolen Kristiania

www.h-ck.me/eth2100/exam25/ETH2100_H25_mappeeksamen_del2_pentest.pdf

Hvis problemer – spør i øvingstimene

- Alle spørsmål til mappeinnleveringen skal stilles til foreleser, veilederne har ikke lov til å svare på noen spørsmål relatert til eksamen
- *Det blir ordinær veiledning til ukens øvingsoppgaver fremover*

- Foreleser kan kun hjelpe hvis du ikke får STARTET test maskinen, eller noe ser ut til å ikke virke inne i VMen - det vil ikke bli gitt noe hjelp til å faktisk løse eksamen

- Spørsmål vil kun besvares i øvingstimene, hvis det er spørsmål som er relevante for flere vil det opplyses om det i forelesning

Høyskolen Kristiania

Nynorsk

Emnekode:	ETH2100
Emnenamn:	Etisk Hacking
Vurdering:	Mappevurdering, DEL 2
Innlevering:	21. november 2025
Filformat:	PDF (ingen vedlegg)

Eksamen er ei mappevurdering og består av 3 delar. Delane skal leverast som 3 ulike innleveringar i Wiseflow. Karakter blir sett basert på ALLE delane som ein heilskap, alle 3 delane må vere beståtte. Sjå første førelesing for detaljar om karaktersetjing.

Krav til DEL 2

- Filnamn skal vere [kandidatnummer]_ETH2100_Eksamen_DEL2.pdf
- Skriven som ein profesjonell rapport
- Ved bruk av kjelder blir dette skrive i «pentest-rapport»-form; ikkje litteraturliste eller referansar på slutten, men på form:
  - For meir detaljar sjå her: www.vg.no

Du får lov til å kopiere det du sjølv har skrive i ditt eige arbeidskrav. Eg har opplyst i førelesinga, og har skrive inn i sensorrettleiinga, at det IKKJE er plagiat. Føremålet med arbeidskravet er å førebu dykk til eksamen, eg forventar derfor at de vil byggje vidare på rapporten de skreiv til arbeidskravet.

Boris' Lockpicks

Høyskolen Kristiania

www.h-ck.me/eth2100/exam25/ETH2100_H25_mappeeksamen_del2_vm.zip

www.h-ck.me/eth2100/exam25/ETH2100_H25_mappeeksamen_del2_source.zip

(Vêr obs på at dette domenet blir brukt i undervisning av etisk hacking, antivirusprogrammet ditt kan derfor rapportere domenet som «malicious», du må i så fall leggje til eit unntak for domenet …)

Boris Lockpicks

Kunden er Boris Lockpicks, og han har fått utvikla ein nettbutikk som no er i betaversjon. De har tidlegare jobba på prosjektet og kjenner koden frå tidlegare.

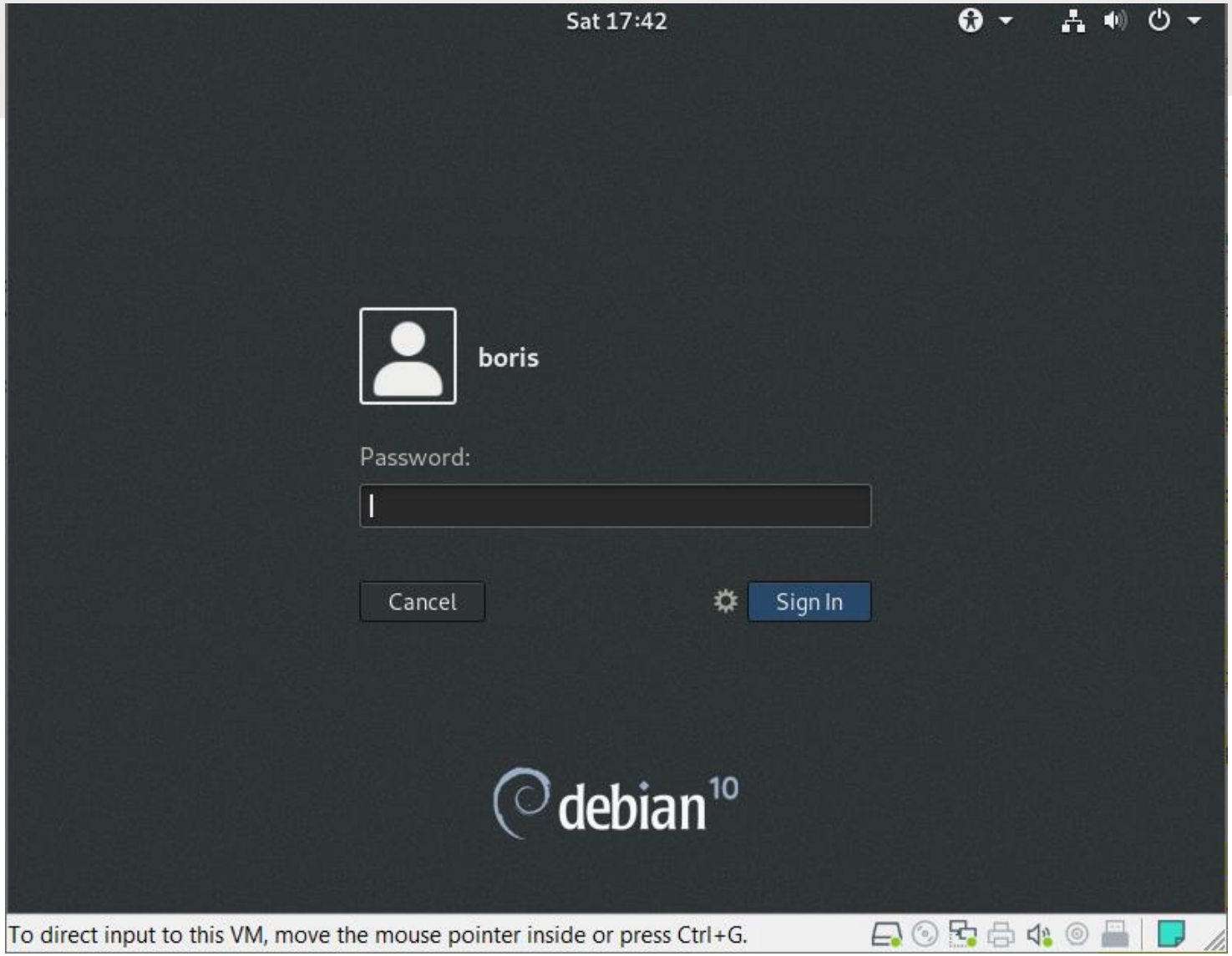
Kunden ønskjer å gjennomføre ein Web Application «pentest» av applikasjonen. Testen skal gjennomførast som ein whitebox test, og de bør gjennomføre statisk kodeanalyse.

Kjeldekode er lagd ved i fila `ETH2100_H25_mappeeksamen_del2_source.zip` som de kan både finne under EKSAMEN på Canvas, eller på URL-en nemnd over.

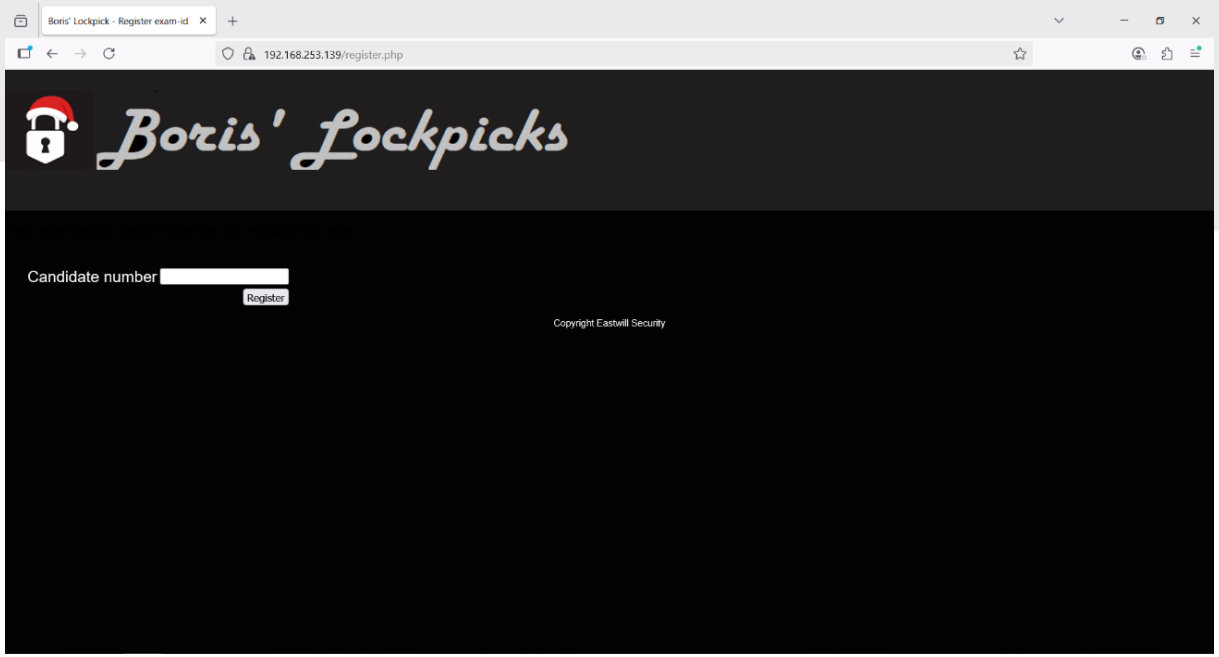
Boris Lockpicks

Kunden har ikkje opplyst om nokon brukarar eller passord til systemet. (Det er innanfor scope å knekkje passord for innlogging, og dersom det er mogleg å finne passordet, skal det i så fall rapporterast som ei sårbarheit.)

De må først finne IP-adressa til tenaren. Tenaren bruker dynamisk IP-adresse gjennom DHCP som den vil få frå deira VMWare, men då de ikkje får innloggingspassord til tenaren, må de sjølv finne IP-adressa som blir tildelt.

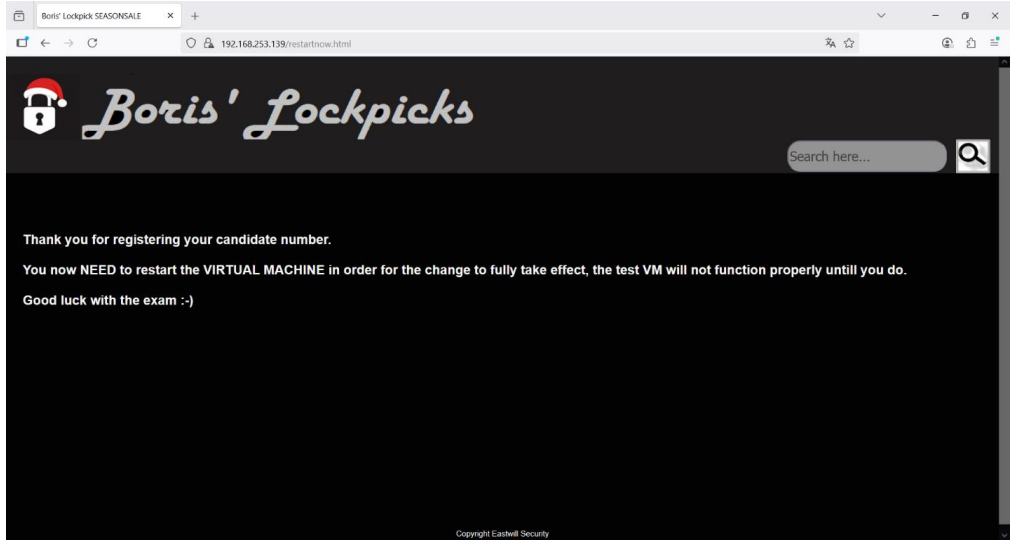

Sat 17:42
boris
Password:
Cancel
Sign In
debian 10
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

1.



2.

Etter at du har registrert kandidatnummeret ditt, må maskina startast på nytt. Når du trykte 'Register', skal du ha fått opp denne sida:



Før du kan starte testing av maskina må du først registrere kandidatnummeret ditt. Det gjer du ved å opne IP-adressa du fann som køyrer webapplikasjonen og gå til nettsida **register.php**.

192.168.253.139/register.php [Erstatt IP-adressa med IP-adressa til di VM]

3.

Etter ein omstart vil delar av serveren tilpasse åtferda si til kandidatnummeret du registrerte.

Boris Lockpicks

Det skal gjennomførast ein «penetrasjonstest» (teknisk sårbarheitsrevisjon) av ein web-applikasjon.

Applikasjonen kan lastast ned frå H-CK.ME (lenkje til fila frå emnesidene på Canvas), og ligg i fila `ETH2100_H25_mappeeksamen_del2_vm`. Fila inneheld eit VMWare image de skal starte, og som køyrer ein web-applikasjon.

Imaget er konfigurert til berre å bruke adapteret Host-Only (VmNet1).

Oppstart av tenaren

Web-tenaren Abyss WS startar automatisk i bakgrunnen når de startar den virtuelle maskina (de treng ikkje starte noko manuelt, og treng ikkje logge inn). Installasjonen bruker HTTPS, og kan aksesserast i ein nettlesar (til dømes) med https://192.168.253.140/ frå ei anna maskin (Kali VM eller host-maskina). Merk at då IP er dynamisk tildelt, vil IP-adressa vere ulik på systema dykkar.

De skal ikkje trenge å logge inn på tenaren, Abyss startar i bakgrunnen utan innlogga brukar.

Då nettbutikken er i ein betafase, kan det vere noko funksjonalitet som ikkje fungerer etter føremålet.

Out of scope

Viktig:

Dette er eit fiktivt oppdrag til eksamen, derfor er «**Open Source Intelligence**» og «**Social Engineering**» out-of-scope og **skal ikkje utførast.** (De har **ikkje** løyve til å utføre noka testing eller simulere angrep mot selskapet Eastwill Security.)

Innlevert oppgåve kan derfor hoppe over desse stega i både metodikk og rapportering.

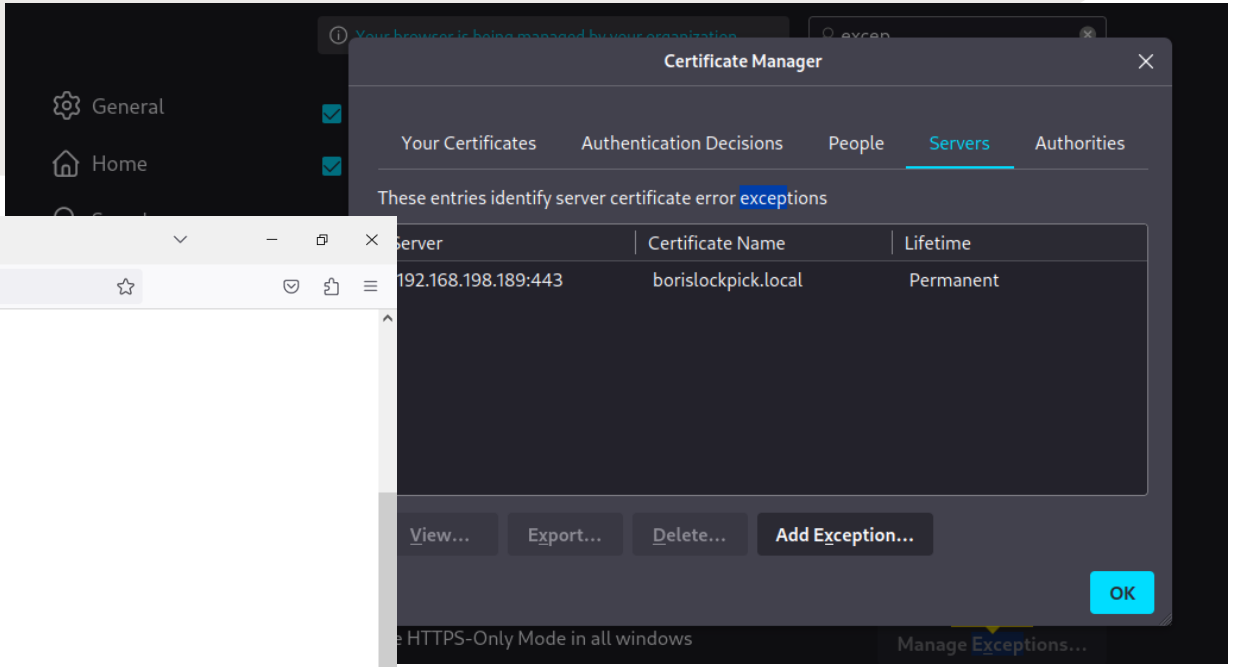
HTTPS-sertifikat

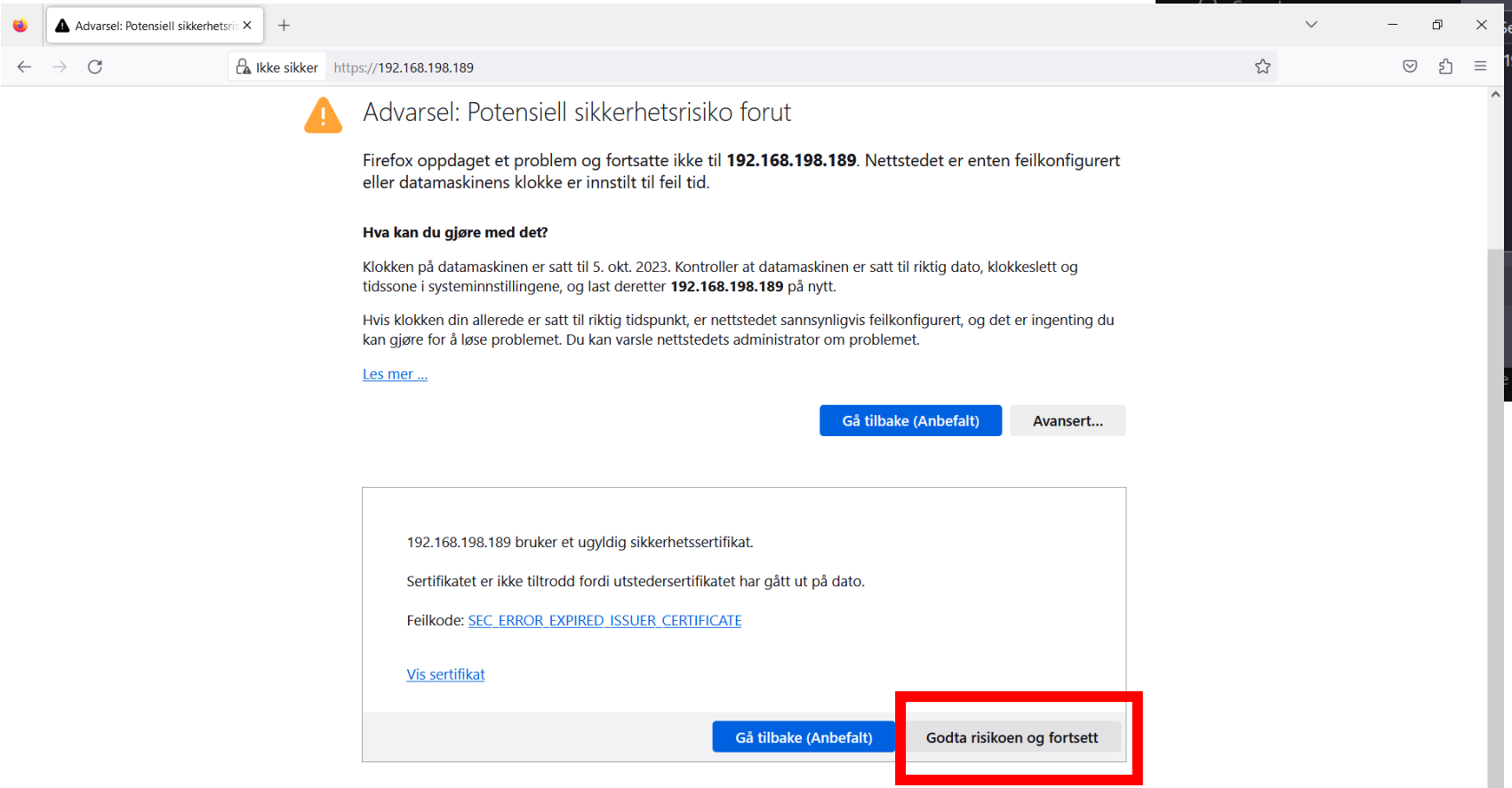
Viktig:

Då tenaren ikkje er i produksjon og ikkje har eit offentleg domenenamn, er det brukt «Self Signed» TLS-sertifikat.

1) At sertifikatet er «Self Signed», er ikkje ei sårbarheit og treng ikkje inkluderast i rapporten.
2) Sertifikatet som vil bli brukt i produksjon, er elles likt det sertifikatet som her er sett opp.
3) Nettlesarar (som Firefox) vil sjå på tenaren som utrygg då sertifikatet ikkje kan validerast – dette må de akseptere.

HTTPS-sertifikat





Innlevering av rapport

Kunden ønskjer at de testar alt på tenaren, ikkje berre web-tenaren på port 443.

Det blir presisert at det skal leverast ein skriftleg rapport frå denne delen av mappevurderinga, og denne rapporten skal leverast inn i Wiseflow, innan den endelege fristen for denne delen.

Høyskolen Kristiania

www.h-ck.me/eth2100/exam24/ETH2100_H24_mappeeksamen_del2_pentest.pdf

Dersom problem – spør i øvingstimane

- Alle spørsmål til mappeinnleveringa skal stillast til førelesar, rettleiarane har ikkje lov til å svare på nokon spørsmål relaterte til eksamen.
- *Det blir ordinær rettleiing til øvingsoppgåvene kvar veke framover.*

- Førelesar kan berre hjelpe dersom du ikkje får STARTA testmaskina, eller noko ser ut til ikkje å fungere inne i VM-en - det vil ikkje bli gjeve noka hjelp til faktisk å løyse eksamen.

- Spørsmål vil berre svarast på i øvingstimane. Dersom det er spørsmål som er relevante for fleire, vil det opplysast om det i

Høyskolen
Kristiania